What we have

The theory of security of learning procedures, as it stands on 26 October 2026

We price an adversary against a learning procedure in the units of learning: samples, training runs, queries, and the compute of a learner class. A price is proven either for every adversary (the statistical side) or for adversaries that must compute efficiently (the computational side), and a good result relates it to the trainer's own price. Every result below is proven and accepted by a discussant unless its label says otherwise. None is checked by you yet. Booklet numbers refer to `lib/theory/booklet.pdf`, and "new" marks a result of the second milestone, not yet in the booklet.

1. The objects

A *learning function* $\mathsf{L}(x; \rho, \xi)$ maps a training input x (learner, starting model, dataset, hypothesis class), a seed ρ and hardware randomness ξ to a model. The *learning oracle* answers three calls. $\mathsf{Train}(x, s)$ trains and returns a name for the model, drawing a fresh seed when $s = \perp$ and reusing a stored seed when s names one. Eval evaluates a stored model, and Open returns it. A caller in the *named mode* may reuse seeds, a caller in the *drawn mode* may not. Under the *bottom oracle* the adversary sees only the procedure, and under the *top oracle* it also holds the honest seeds.

The *twin* of a training run is the same run, with the same seed, on the neighbouring dataset. The *coupled tail* $\epsilon_0(\Delta)$ is the probability that a run and its twin differ by more than Δ. A *certifier* is an experiment that outputs an upper bound on a leakage target from Train calls, and it is *sound* when the bound holds for every learning function. The *security profile* maps an adversary's budget to its best success.

For split learning, the class $\mathcal{P}_H$ holds protocols whose client applies a first layer $W\pi(x)$ and whose training is equivariant under a group H of rotations, plain SGD from a Gaussian start for instance. Its server never sees the weights or the records. A *seed-known* server knows the client's initialization, and a *seed-blind* one does not. The *pancake law* $H_{v,\beta,\gamma}$ is Gaussian except along a hidden direction v, where it concentrates on thin parallel layers. Detecting it is homogeneous CLWE, which is hard unless worst-case lattice problems are easy for quantum algorithms.

A single-index law has labels that depend on $Z = \langle u, x\rangle$ alone. Its *generative exponent* k^* is the least Hermite degree k with $E[h_k(Z) \mid Y] \neq 0$. Statistical-query and low-degree learners need of order $d^{k^*/2}$ samples to find u, and an efficient algorithm matches it.

A *mapping* is a reduction, in either direction, between an attack task on a procedure and a hard problem from the literature. It states the price on both sides, the regime (statistical-query, or polynomial time under a named assumption), the carrier of the hardness, and an experiment.

2. Measuring leakage with the oracle

1. Coupling certificate (booklet 3.8). For one training run, the leakage of any channel is at most the coupled divergence over same-seed pairs, which is at most the probability that a run and its twin differ. Named-seed runs certify it for every learning function. Drawn-seed runs cannot certify the total variation below one through a deterministic channel.
2. Needle lower bound (booklet 3.6). If J learning functions differ from a reference only on disjoint sets of inputs, a certifier with N Train calls is fooled at the reference with probability at least $1 - \alpha - N/J$.
3. Black-box certifiability (booklet 3.9). With finitely many queries and outputs, the best advantage of q label queries is certifiable from drawn-seed runs, with error falling as the inverse square root of the number of runs.
4. Dataflow composition (booklet 3.10). A client isolated behind Gaussian releases leaks at most a Gaussian term plus the coupled tail. Coupled runs certify that tail with a number of runs free of the dimension, and drawn-seed certifiers pay exponentially in $\min\{d, B^2/\sigma^2\}$.
5. Bounded-deviation transfer (booklet 3.11). A coalition that deviates by at most B_A raises the tail to a fixed function of the honest one, and certifying that costs about $e^{\mathfrak{e}}$ runs, with $\mathfrak{e} = (R-1)B_A^2/(2\sigma^2)$, matched by a lower bound.
6. Replay-audit steering (booklet 3.12). When seeds come from a random oracle, a prover with q queries passes n replays with a chosen model at most $(q+1)n$ times as often as an honest run lands there. This one uses a random oracle as a plug-in.
7. Drawn seeds stay sound (booklet 6.1 to 6.3). One oracle serves both modes. Every certificate above stays sound under independent drawn runs for bottom-oracle targets, so a shared seed buys accuracy, never soundness. Independence from the release noise is necessary.
8. The price of twins (booklet 6.5). A sound certifier that shows near-zero leakage makes about $\ln(1/\alpha)/\epsilon_{\text{acc}}$ calls at the twin input. That is 686.5 calls when both failure probabilities are 10^{-3} and $\epsilon_{\text{acc}} = 10^{-2}$, and 4.1×10^7 for every record of 60,000. Runs at any other input, fine-tunes included, count for nothing.
9. Profiles are flat in runs (booklet 6.4). Against an unrestricted adversary, extra Train calls add nothing, so a profile is measurable only for a named family of attacks. Fresh shadow runs give a lower band for that family, and only coupled runs give an upper band.

3. Statistical prices: the unbounded attacker

10. Shadow-run price (booklet 4.3). Coming within a of the best advantage on every learning function with k possible views costs $\Theta(k/a^2)$ Train calls, against the trainer's one run. Chosen or opened seeds do not lower it. Under the top oracle with deterministic training, one call at the honest seed suffices.
11. Label sandwich (booklet 4.4). From a representation Z, an unbounded reconstructor succeeds at least as often as the class baseline minus the label error, and at most that baseline plus $\sqrt{I(X;Z \mid Y)/2}$. An injective representation gives up everything.
12. Orbit limit and price (new). A seed-blind server learns the records only up to the symmetry group of the record law. For Gaussian records it cannot place even one record within $\sqrt{d}/(2\sqrt{2})$, except with probability $e^{-\Omega(d)}$. Up to that rotation, for linear clients, the minimax price is $\Theta(d^2/N)$ per record, and empirical whitening attains it.
13. ReLU clients give up their weights (new). For Gaussian records, the second moment of a Gaussian ReLU client's outputs determines its weights up to rotation, so the server inverts every record up

to that rotation in polynomial time. This holds at the population level, and the sample price is open.

14. Same-units gap (new). For the Gaussian mechanism on the mean, with noise $\rho\Sigma^{1/2}\xi$ and $\rho = n^{-a}$, $0 < a < \frac{1}{2}$, membership costs the attacker $\Theta(1 + n\rho^2)$ times the trainer's price in samples plus Train calls, and an efficient attack attains it. Train access moves the price from reference samples to Train calls, but leaves the total unchanged. This is proven, under the hypothesis that the noise follows the population covariance, so that Train calls leak it.

4. Computational prices: mappings onto hard problems

15. The seed separates attackers (booklet 5.6 to 5.8). On pancake records, behind a Gaussian ReLU client, a seed-known server inverts every record with one linear program each. A seed-blind statistical-query server needs $\exp(\Omega(c_0^4 d))$ queries for correlation c_0. A seed-blind polynomial-time server reconstructs finely only if homogeneous CLWE is easy. The mechanism is that the server's whole view is a function of randomly rotated records.
16. Coarse reconstruction is lattice-hard (new). Reconstructing pancake records to any constant correlation is as hard as homogeneous CLWE. Two independently rotated reconstructions that agree reveal the hidden direction. Proven in an exact-arithmetic model.
17. The two attacker games differ (new). With exactly discrete hidden labels behind a hidden linear client, a polynomial-time server reads the labels from $d + 1$ representations by lattice reduction, while every statistical-query tester needs $2^{d^{\Omega(1)}}$ queries or polynomially small tolerance. Proven in exact arithmetic.
18. Quantized records and ZLIP (new). For records drawn from the integer lattice, blind reconstruction is at least as hard as recognizing a rotated $\mathbb{Z}^d$, and for a linear client no harder. Sketch. The mathematics is accepted, and one challenge on the arithmetic model is open.
19. A good predictor gives up the label direction (booklet 5.9, 5.10). A server holding the top model, with excess risk ε, recovers the label direction to within $O(\sqrt{\varepsilon})$ and reconstructs that coordinate of every record. From the labels alone, the price of that coordinate is set by the task's generative exponent, $d^{k^*/2}$. The converse, that reconstruction costs what training costs, is refuted (booklet 5.11).
20. Extraction costs twice the trainer's exponent (new). Take labels with $E[Y \mid Z] = |Z|e^{-Z^2/2}$. Their exponent is 2, so the trainer finds the direction from $O(d)$ records. The released predictor's link has exponent 4, because on each of its level sets a Gaussian keeps its first three moments. A statistical-query extractor of the release, from random inputs, therefore needs $\mathrm{VSTAT}(c\,d^2)$, and $O(d^2)$ answered pairs suffice. The comparison of records with a VSTAT parameter is heuristic, and chosen inputs break the separation.
21. A learner's SQ bound binds every attacker (booklet 5.2, generalized by a new result). If a procedure reads its data only through one-bit statistical queries, any SQ-hard test bounds every attacker of its output, even an unbounded white-box one.

5. What the literature got wrong

- FORMAL_SECURITY's proof note `.tools/proof.tex`. Its main theorem is false, by a half-page counterexample (booklet 5.1).
- Goldwasser, Kim, Vaikuntanathan and Zamir, Appendix A. The sparse-PCA backdoor is detected at its printed parameters, and its activation condition fails. Their main CLWE construction stands.

- Feldman et al., J. ACM 2017, Theorem 3.16, has one wrong sign. Mukherjee and Lokam, arXiv 2303.16372, Theorem 10 and Corollary 12, are not established. Zadik, Song, Wein and Bruna, COLT 2022, Theorem 3.3, fails when all labels but the first vanish.

6. What is open

Two conjectures stand. The first says the seed is worth exactly the NGCA price of the record law (booklet 5.12). It is settled from below, and from above for linear clients. The second asks for a same-units gap for low-rank adapters (booklet 7.1). Further open problems are the sample price of blind ReLU inversion, extraction of a fitted rather than exact release, and finite-precision versions of the lattice results.

Six decisions are yours: 1. Is the Train-access model of result 14 right? 2. Are results in exact arithmetic acceptable for now? 3. Is learning-based extraction from random inputs a game worth pricing? 4. Is the mapping definition's carrier rule your reading of "a cryptographic plug-in does not count"? It counts hardness carried by the data law, by honest randomness, or by a trainer's planted choice. 5. Should a round go to the ZLIP sketch? 6. Should the new results enter the booklet, and in what form?

The new results, with their proofs, are in `sink/formalizing/results.md`, under the heading for milestone 2.